CHS security audit and fixes

18 October 2026 · Build 9 · round 2 · for the CHS team

What this document is

A plain account of what was checked, what was found, what was fixed, how each fix was tested and what is **not** covered. Earlier messages said the platform was secure without a test behind every claim. This audit was done by attacking the system as an ordinary stranger and recording what got through. It does not say the platform is perfectly safe. It says what was tested and what is left.

How it was tested

- A stranger account was chosen: a real user with no connection to any property, booking, tenancy, offer or shop. Its wallet was given a large balance inside the test so that “not enough money” could not hide a security failure.
- That account called more than 450 database functions, each against about 60 real records belonging to other people, roughly 19,000 calls. Any call that worked was treated as a hole.
- The same stranger tried to write directly into the tables, change its own role, forge notifications and read private data.
- Every test was rolled back. No real money, record or message was changed.
- The edge functions (the server programs for payments, sign-up, withdrawals and reminders) were read line by line.

What was found and fixed

Problem	Who could exploit it	Now
A user could edit their own profile directly, including role and the super-admin flag	Any logged-in user	Refused by a database guard
Direct writes to offers, bookings, tenancies, bank accounts, approvals, promotions, notifications, properties	Any logged-in user	Refused for non-admins; our own buttons still work
Direct writes to documents, inspections, quotes, disputes, product status, notices, condition and fault reports (self-verifying documents, setting own inspection fee or payment status, approving own vendor)	Owners, tenants, vendors, requesters	Refused; admin-only fields are controlled by CHS
apply_admin_action could be run by any logged-in user and applied a stored admin action (clear a sale, approve a profile, freeze or unfreeze a wallet, mark a referral paid) even if never approved	Any logged-in user with a request id	No longer callable from the app. Found today
Payment webhook trusted the credits or unlock value written in the payment details instead of the amount actually paid	Anyone who starts a Paystack payment themselves	Now checks amount, currency and success status. Found today
add-role-to-account accepted any role text, including admin	Any logged-in user	Only ordinary roles allowed; admin accounts cannot be changed there. Found today
Owner checks that passed when the owner field was empty (about 106 functions)	Any logged-in user	Rewritten to refuse
Logged-out visitors could call about 260 money, admin and internal functions	Anyone on the internet	Only 39 public-page functions remain open

Problem	Who could exploit it	Now
Forgot-PIN could be guessed	Anyone with a phone number	5 wrong tries per phone per hour then locked; admin accounts excluded
Guarantor ID document readable by anyone with the link	Anyone	Open read removed; admin opens it by a short-lived link
Notifications and audit entries could be forged	Any logged-in user	Direct sending only to people you deal with; audit log internal only
Free promo credits by direct call	Any logged-in user	Removed
Internal secret written inside a file in the repository	Anyone with the zip or GitHub	Secret rotated (old one is dead) and removed from the file
Sending money did not need the Payment PIN; withdrawing to a bank still did not	Someone using a stolen logged-in phone	Both now require the PIN
Sign-up allowed choosing an admin role; account lookup revealed names	Anyone	Role whitelist; masked name and rate limit
189 database functions had no fixed search path	Defence in depth	Pinned
NIN stored as a plain number	Anyone who could read the database	Stored as a keyed hash plus last 4 digits; the plain number can never be saved again
A staff admin could make themselves super admin by editing their own profile	A staff admin account	Refused; staff can only mark verification and read status on others. Found in round 2
A staff admin could change any platform setting, fee or PIN switch	A staff admin account	Super admin only. Found in round 2
Admin buttons to mark an agent ID or manager credentials verified silently did nothing	Admins (a functional bug)	Fixed, within the staff limits above
Wallet balances, ledger, withdrawals, rent, rent-to-own, sale installments and commissions could be written directly through the API by any super admin	A super admin account (or tooling using it)	Refused for everyone; money moves only through the payment functions
Lookups usable to test phone numbers or bank accounts (transfer recipient, bank-name check, biometric login)	Anyone signed in, or anyone for biometric login	Rate limited; biometric login gives one identical answer

What users and the team will notice

- To withdraw to a bank or send money to another user, a Payment PIN is now required. People without one will be asked to create it first.
- Owners and others can no longer set approval, verification, fee or payment fields themselves. Those come from CHS actions.
- Three pages change in this zip (forgot PIN, guarantor confirm, admin guarantor document buttons). Everything else was changed in the database and is already live.

What is NOT covered

- Staff admins: since the evening of 18 October every direct write by a staff admin is limited to their own area (customer care, registration, owner/buyer/tenant, agent relations, artisan/developer/vendor) and money tables, settings and bank details are super-admin only. Tested with a rolled-back attack run. A staff account can still do everything its own area allows, so keep staff accounts few and review alerts weekly.

- ID numbers typed on ID-verification forms (not the NIN in the profile) are stored as typed, because an admin must read them to compare with the document.
- Account hygiene outside the code: two-step sign-in and separate logins on Paystack, Supabase and GitHub for each person; rotate the Paystack key if anyone who knew it leaves.
- The NIN hash secret (nin_pepper in private_secrets) must never be deleted; without it forgot-PIN matching stops working for everyone.
- No outside penetration test has been done. Before large volumes of money, commission one.

Tests for the team (each should be refused unless it says works)

- Logged in as an ordinary tenant or buyer, the admin tools are not available.
- Forgot PIN: five wrong NINs on one phone lock it for an hour; a correct phone and NIN on a fresh try works.
- Withdraw and send-money both ask for the 6-digit Payment PIN.
- An owner’s uploaded property document stays “pending” until admin verifies it.
- Guarantor link: upload and sign works. Admin can open the ID from the application. The old direct link, logged out, shows nothing.
- Logged out (private window): home, a property page, a hotel page, verify-agent, verify-chs, tenant invite and split-payment pages all still load.
- Buy promo credits and unlock a roadmap with a test payment: both still work with the right amounts.
- Add a role to an existing account (agent or manager) works; there is no admin option.
- Admin approvals and releases still work, with a super admin for the second approval.
- Forgot PIN still works with the right NIN for an existing account; registering with a NIN already used is refused.
- Admin: Mark ID verified on an agent application now stays verified. A staff (not super) admin cannot open Settings or change roles.

If something that should work says “not allowed”: send the exact message and the screen to the developer. Do not switch security off. Technical detail, migration names and how to undo any single fix: backend-v2/536_security_audit_18_oct_2026.sql.md.